

MFA Strategy Overview

The Multi-Factor Authentication (MFA) strategy for FinSecure Pvt. Ltd. is designed to enhance the organization's authentication framework by introducing layered security controls across all critical systems while maintaining operational efficiency.

Given FinSecure's hybrid IT environment—comprising on-premise Active Directory and cloud-based Microsoft 365 services—the MFA strategy adopts a **centralized and scalable approach** to ensure consistent enforcement of authentication policies across all platforms.

The strategy is based on the following core principles:

2.1. Layered Authentication (Defense-in-Depth)

Authentication will no longer rely solely on passwords. Instead, it will combine multiple factors:

- **Something you know** (password/PIN)
- **Something you have** (mobile device, hardware token)
- **Something you are** (biometric verification)

This significantly reduces the risk of unauthorized access due to compromised credentials.

2.2. Risk-Based Authentication

MFA enforcement will be dynamically triggered based on contextual risk factors such as:

- Login from a new or untrusted device
- Access from unusual geographic locations
- Attempts to access high-privilege systems

This ensures stronger security without unnecessarily impacting user experience.

2.3. Centralized Identity & Policy Management

All authentication policies will be managed through a centralized identity provider, ensuring:

- Uniform MFA enforcement across systems
 - Simplified administration for the IT team
 - Consistent user authentication experience
-

2.4. Prioritized Protection for High-Risk Areas

The strategy focuses on securing critical assets first:

- Administrative and privileged accounts
 - VPN and remote access systems
 - Microsoft 365 and cloud services
 - Client-facing web applications
-

2.5. Phishing-Resistant Authentication

Where feasible, the strategy emphasizes the use of phishing-resistant MFA methods such as:

- Authenticator apps with secure verification
- Hardware tokens (FIDO2/WebAuthn)

This aligns with modern security best practices and reduces susceptibility to social engineering attacks.

2.6. User-Centric Design

The MFA system will be designed to minimize friction for end users by:

- Leveraging Single Sign-On (SSO)
 - Reducing repeated authentication prompts
 - Providing multiple authentication options
-

2.7. Scalability and Future Readiness

The solution will support:

- Expansion to additional users and systems
 - Integration with new cloud services
 - Adoption of advanced authentication technologies
-

2.8 MFA Method Selection

2.8.1 Evaluation Criteria

Methods were evaluated across five dimensions relevant to FinSecure's hybrid environment and 400-user base:

- Security strength — resistance to common attacks
- Phishing resistance — immunity to credential interception
- Usability — ease of use for non-technical staff
- Integration feasibility — compatibility with Entra ID and AD
- Cost — licensing or hardware overhead

2.8.2 Method Comparison

Method	Security	Phishing Resistant	Usability	Entra ID Support	Cost	Verdict
Authenticator app (TOTP/push)	High	Moderate (push vulnerable, TOTP safer)	High	Native	Low	Primary
FIDO2 hardware token (YubiKey)	Very High	Yes	Medium	Native	Medium-High	Admins/privileged
Biometrics (Windows Hello)	High	Yes	Very High	Native	Low (device-bound)	Trusted devices
SMS OTP	Low	No	High	Supported	Low	Fallback only
Email OTP	Low	No	High	Supported	Low	Fallback only

2.8.3 Selection Rationale

Authenticator app is selected as the primary method because it balances security and usability for a 400-person workforce with no dedicated security team. Microsoft Authenticator integrates natively with Entra ID, requires no additional licensing, and supports both TOTP and push notifications. Number matching and limited push retries are enforced to mitigate MFA fatigue attacks.

FIDO2 hardware tokens (YubiKey 5 series) are mandated for IT administrators and privileged accounts because they are fully phishing-resistant via public-key cryptography — no shared secret is transmitted during authentication. While FIDO2 offers the highest level of security, deploying it across all 400 users would introduce significant cost and operational overhead. Therefore, it is selectively applied to high-risk roles where the security benefit justifies the investment.

Biometrics via Windows Hello for Business are enabled on corporate-issued laptops as a convenience layer. Biometric authentication is enforced only on compliant, Intune-managed devices to prevent unauthorized device usage. Since biometric data is stored locally in the device TPM and never transmitted, it adds strong authentication without central data risk.

SMS and Email OTP are retained strictly as fallback methods for account recovery scenarios. They are explicitly disabled as primary methods for all privileged accounts given their susceptibility to SIM swapping and email compromise respectively.

2.8.4 Method-to-User Mapping

User Group	Primary Method	Fallback	Notes
All employees	Authenticator app	SMS / Email OTP	Mandatory enrollment
IT administrators	FIDO2 hardware token	Authenticator app	No SMS/email fallback
Finance & HR	Authenticator app	Email OTP only	Higher risk — SMS disabled
Remote workers	Authenticator app	SMS OTP	VPN access requires MFA
Contractors	Authenticator app	Email OTP	Time-limited access

2.9 The MFA architecture for FinSecure Pvt. Ltd.

The MFA architecture for FinSecure Pvt. Ltd. is organized into four layers: users, identity management, MFA challenge, and protected systems. Figure 2 illustrates the structural relationship between these layers.

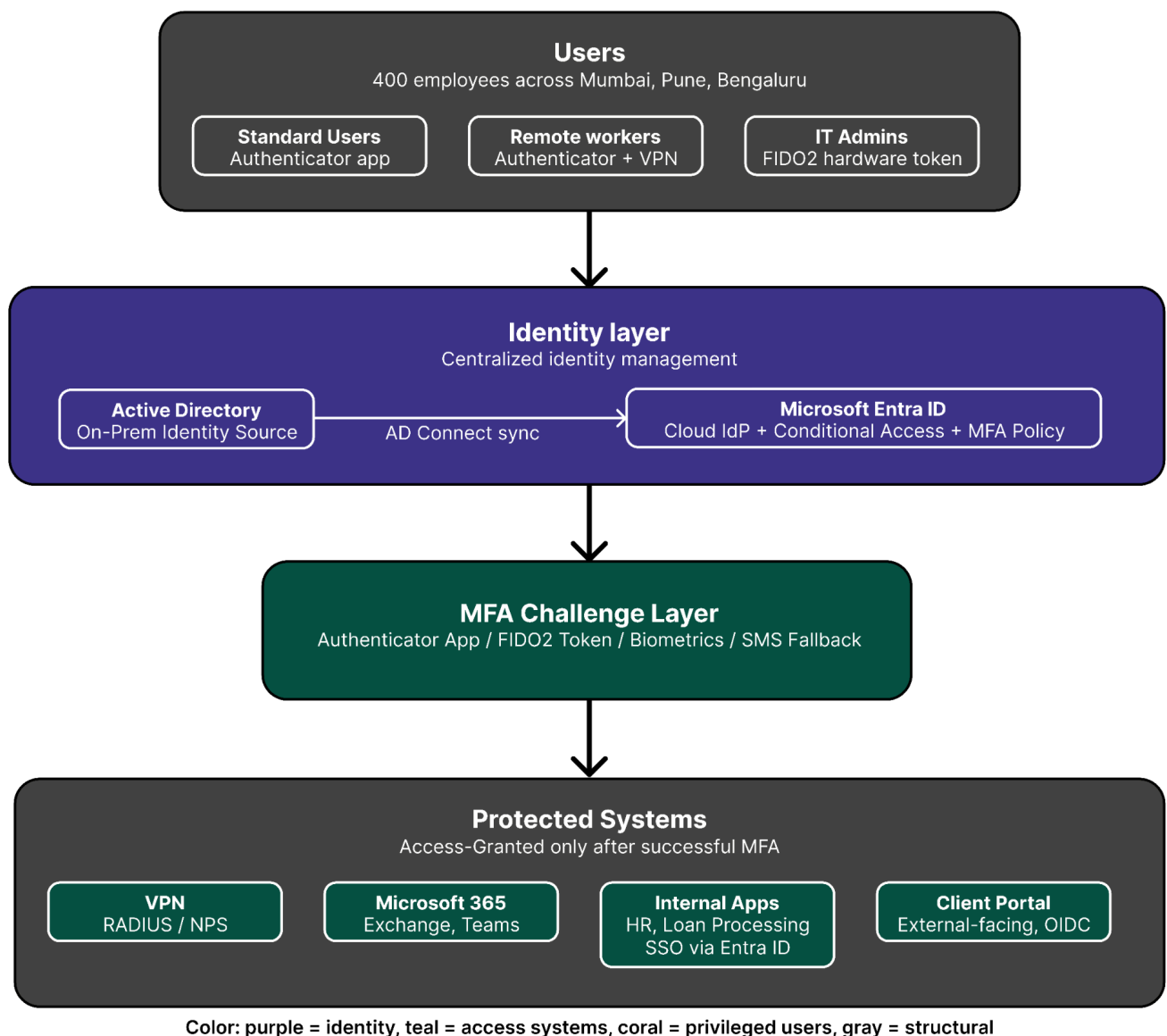


Figure 2: FinSecure MFA architecture — identity and access layers

Figure 3 shows the step-by-step authentication flow a user experiences from login attempt through to access granted or denied.

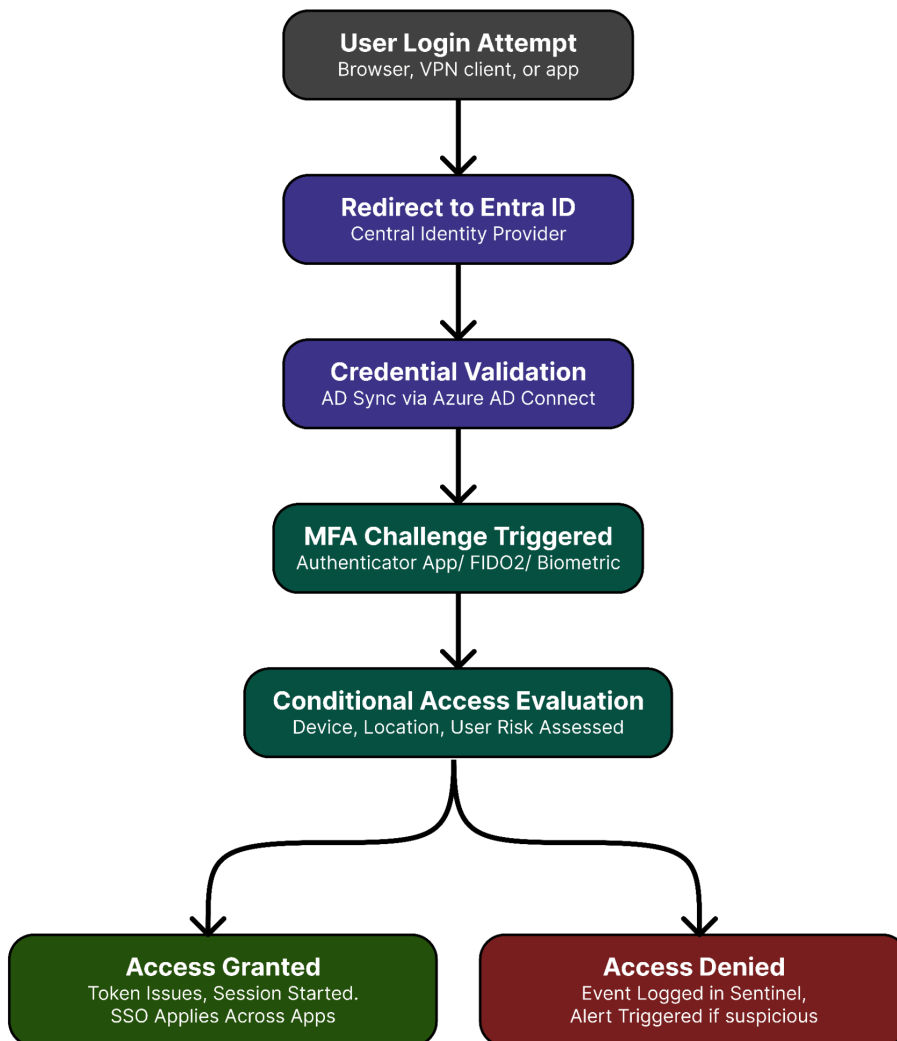


Figure 3: FinSecure MFA authentication flow — step-by-step login process

2.10 Integration Points

2.10.1 Overview

The MFA solution integrates with FinSecure's existing systems through Microsoft Entra ID as the central control point. Each system connects to the MFA layer differently depending on its type, protocol support, and risk classification.

2.10.2 Integration Map

System	Integration Method	Protocol	MFA Enforcement Point	Notes
Active Directory	Azure AD Connect sync	LDAP → Entra ID	Entra ID cloud layer	Password hash sync recommended
Microsoft 365	Native Entra ID integration	OAuth 2.0 / OIDC	Conditional Access policy	No additional config needed
VPN	RADIUS via NPS + MFA extension	RADIUS	NPS server	Azure MFA NPS Extension required
HR application	SSO via Entra ID	SAML 2.0	Entra ID SSO	App must support SAML federation
Loan processing system	SSO via Entra ID	SAML 2.0	Entra ID SSO	Legacy apps may need reverse proxy
Client portal	App registration in Entra ID	OIDC	Entra ID app registration	Authorization Code Flow
RDP / remote desktop	Azure AD joined devices	RDP + Entra ID	Device compliance policy	Requires Intune enrollment
Admin accounts	FIDO2 direct registration	FIDO2 / WebAuthn	Entra ID FIDO2 policy	Hardware token mandatory

2.10.3 Integration Architecture Notes

Active Directory remains the on-premise identity source. Azure AD Connect synchronizes user accounts, groups, and password hashes to Entra ID every 30 minutes by default. This means all MFA enforcement happens at the cloud layer — even users authenticating to on-premise systems pass through Entra ID for the MFA challenge.

For applications that don't natively support SAML or OIDC — such as the loan processing system — a reverse proxy or application gateway can be placed in front of the app. The proxy handles authentication with Entra ID and only forwards requests that have passed MFA. This avoids modifying legacy application code.

The VPN integration is the most architecturally complex. The NPS server acts as a RADIUS broker between the VPN gateway and Entra ID. When a user connects, the VPN sends credentials to NPS, NPS validates them against AD, then triggers an MFA challenge through the Azure MFA NPS Extension before returning an access-accept or access-reject to the VPN gateway.

2.10.4 Conditional Access Policy Mapping

Scenario	Policy Triggered	Result
Login from known device + normal location	Standard MFA	Authenticator app prompt
Login from new device	Step-up MFA	Additional verification required
Login from unusual country	High-risk policy	Block or require FIDO2
Admin account login (any scenario)	Always-on MFA	FIDO2 mandatory, no exceptions
VPN connection attempt	MFA required	RADIUS triggers Entra ID challenge
Outside business hours (privileged accounts)	Alert + MFA	Logged and flagged in Sentinel

2.10.5 SSO Coverage Summary

Once authenticated through Entra ID with MFA, users gain SSO access to all connected applications without re-authenticating. This covers Microsoft 365, the HR application, the loan processing system, and the client portal. VPN requires a separate authentication event since it operates at the network layer rather than the application layer.

2.11 User Experience Design

2.11.1 Overview

A secure MFA system is only effective if users actually use it correctly. Poor user experience leads to workarounds, helpdesk overload, and shadow IT. The MFA design for FinSecure Pvt. Ltd. prioritizes minimal friction while maintaining strong security, recognizing that the IT team of 8 cannot support a high-friction rollout across 400 users.

2.11.2 Design Principles

- Enroll once, authenticate everywhere — SSO means users register MFA once and access all connected systems without repeated prompts
 - Sensible step-up — MFA is always required at first login but does not interrupt active sessions unnecessarily
 - Choice within boundaries — users choose their preferred MFA method within the options permitted for their role
 - Graceful fallback — if a primary method fails, a secondary method is available without IT involvement
 - Clear communication — every MFA prompt tells the user exactly what is being requested and why
-

2.11.3 User Enrollment Flow

The enrollment experience is designed to be completable in under 5 minutes with no IT assistance.

Step	User Action	System Response
1	User receives enrollment email with link	Entra ID generates enrollment invitation
2	User clicks link and logs in with existing password	Entra ID prompts MFA setup
3	User selects preferred MFA method	Available options shown based on role
4	User follows setup instructions (e.g. scans QR code)	Entra ID registers the device/method
5	User enters verification code to confirm setup	Entra ID validates and confirms enrollment
6	User sets up a backup method	SMS or email OTP registered as fallback
7	Enrollment complete	Confirmation shown, user redirected to home

Self-service enrollment is available through Microsoft's My Security Info portal (mysignins.microsoft.com). Users can manage their registered methods, add backups, and update devices without contacting IT.

2.11.4 Day-to-Day Login Experience

For a standard employee using Microsoft Authenticator:

First login of the day → enter password → authenticator app push notification → approve → SSO grants access to all connected apps for the session.

Subsequent app access within the session → no additional prompts (SSO active).

New device or unusual location → step-up MFA challenge triggered by Conditional Access → re-verification required.

Session timeout after inactivity → re-authentication required.

For IT administrators using FIDO2 hardware token:

Insert YubiKey → enter password → touch the YubiKey button → access granted. No app required, no push notifications, fastest login path for privileged users.

2.11.5 Friction Reduction Measures

Measure	How it works	Benefit
SSO across all apps	Single authentication grants access to M365, HR app, loan system, client portal	Eliminates repeated logins
Push notifications	One-tap approval on Microsoft Authenticator	Faster than entering OTP codes
Number matching	User enters a number shown on screen into the app	Prevents blind approvals, no extra steps
Remembered devices	Trusted devices can extend session duration	Reduces prompt frequency for office users
Self-service recovery	Users reset their own MFA via My Security Info	Reduces IT helpdesk load

2.11.6 Accessibility Considerations

FinSecure's MFA implementation accounts for users with disabilities or specific needs:

Users with visual impairments can use Microsoft Authenticator's screen-reader compatible interface, or opt for hardware tokens which require only a physical touch.

Users without smartphones — such as certain field staff or contractors — are provided with SMS OTP as a fallback or can request a hardware token through IT.

Users with motor impairments who cannot easily type OTP codes can use push notification approval, which requires only a single tap.

Language accessibility is handled through Microsoft Authenticator's multi-language support. IT team communications and enrollment guides should be provided in English and any regional languages relevant to the Mumbai, Pune, and Bengaluru offices.

2.11.7 Helpdesk & Recovery Experience

If a user loses their device or cannot complete MFA:

1. User contacts IT helpdesk
2. IT verifies identity through secondary means (employee ID, manager confirmation)
3. IT generates a Temporary Access Pass (TAP) in Entra ID — a time-limited bypass code
4. User logs in using TAP and re-enrolls their MFA method
5. TAP expires automatically — no cleanup required

Temporary Access Passes are the recommended recovery mechanism as they are time-bound, auditable, and require no permanent policy changes.

2.12 Summary

The user experience design ensures that MFA at FinSecure is secure without being disruptive. By combining SSO, push notifications, self-service enrollment, and clear fallback paths, the system achieves strong authentication coverage while keeping the helpdesk burden manageable for the 8-person IT team.

The MFA strategy for FinSecure aims to establish a **secure, scalable, and user-friendly authentication framework** that mitigates credential-based threats while supporting the organization's operational and business needs.